

Informe de Pentesting

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. | Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información — Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Nicolas Estrella

Username TryHackMe: estrellanico222

8 de octubre de 2026

Índice

1. Datos generales

Cliente	INSECUR S.A.
Contratista (alumno)	Nicolas Estrella
Legajo	31.066.692
DNI	46.547.622
Username TryHackMe	estrellanico222
Email institucional	estrellanico222@gmail.com
Sala de elección (Nivel 2)	Vulniversity
Branch en GitHub	estrella-nicolas
Repositorio	github.com/UCHSeguridad2026/TP_THM
Fecha de inicio	8 de octubre de 2026
Fecha de cierre	10 de octubre de 2026

2. Pre-pentesting

2.1. Alcance del trabajo

El alcance del presente trabajo comprende exclusivamente las máquinas de laboratorio de la plataforma TryHackMe asignadas en la guía de la actividad A08. En particular:

- Núcleo obligatorio: salas «Pentesting Fundamentals» y «Basic Pentesting».
- Sala de elección (Nivel 2): «Vulniversity».

Queda explícitamente fuera del alcance cualquier sistema real, de producción o de terceros. No se realizó ninguna acción contra sistemas ajenos a los entornos controlados de TryHackMe.

2.2. Reglas de Enfrentamiento (ROE)

Las reglas acordadas para esta intervención son las siguientes:

- Permiso: se cuenta con autorización expresa de la cátedra para auditar los entornos de laboratorio indicados.
- Alcance de la prueba: únicamente las direcciones IP asignadas dinámicamente por TryHackMe a las máquinas de las salas del trabajo.
- Reglas: se permiten técnicas de enumeración, escaneo de puertos, descubrimiento de directorios web y fuerza bruta de credenciales, limitadas a los objetivos autorizados. No se ejecutan acciones destructivas ni se afecta la disponibilidad del servicio.

2.3. Autorización

Declaro que cuento con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información para realizar las tareas de hacking ético descritas en este informe, sobre los entornos controlados de la plataforma TryHackMe. Todas las actividades se desarrollaron dentro de dicho alcance y con fines exclusivamente académicos.

2.4. Metodología utilizada

Se adoptó un enfoque de pruebas de caja negra (black box): se partió sin conocimiento previo del funcionamiento interno de los sistemas objetivo, interactuando con ellos como lo haría un atacante

externo. El trabajo se estructuró siguiendo las fases estándar del pentesting, en línea con marcos como PTES y la guía NIST SP 800-115:

1. Recopilación de información (information gathering).
2. Enumeración y escaneo de servicios.
3. Explotación de vulnerabilidades.
4. Post-explotación y escalada de privilegios.
5. Documentación y reporte.

3. Desarrollo: salas resueltas

3.1. Pentesting Fundamentals (núcleo obligatorio)

Sala de carácter teórico, orientada a comprender la metodología y las fases profesionales del pentesting. Se completó en su totalidad (100 %). Los conceptos trabajados incluyen: la definición de prueba de penetración como auditoría autorizada; la clasificación ética de los hackers (white hat, grey hat, black hat); el documento de Reglas de Enfrentamiento (ROE) y sus tres secciones (permiso, alcance y reglas); las metodologías de la industria (OSSTMM, OWASP, NIST, NCSC CAF); y los tres alcances de prueba (caja negra, gris y blanca). Estos fundamentos constituyen la base metodológica aplicada en el resto del trabajo.

3.2. Basic Pentesting (núcleo obligatorio)

Máquina Linux (Ubuntu) orientada a la práctica de enumeración de servicios, descubrimiento web, explotación y escalada de privilegios. La sala se completó en su totalidad (100 %), ejecutando la cadena de ataque completa: desde el reconocimiento inicial hasta la obtención de la contraseña final como usuario privilegiado. A continuación se documentan los hallazgos obtenidos durante la intervención.

4. Hallazgos por fase

Hallazgo H-01 — Servicios expuestos en el objetivo

Fase	Escaneo / Enumeración
Descripción	Mediante un escaneo con Nmap se identificaron cuatro servicios abiertos en la máquina objetivo: SSH (22), HTTP (80) y Samba/SMB (139 y 445).
Componente afectado	Servicios de red del host (SSH, Apache, Samba)
Categoría	Superficie de ataque expuesta
Herramienta utilizada	nmap -sC -sV
Impacto en la Tríada CIA	Confidencialidad / Integridad
Salvaguarda propuesta	Exponer únicamente los servicios estrictamente necesarios; aplicar firewall y filtrado por IP; mantener los servicios actualizados.
Riesgo residual	Bajo (si se aplican las salvaguardas)

Detalle de servicios detectados:

- 22/tcp — SSH — OpenSSH 8.2p1 (Ubuntu)
- 80/tcp — HTTP — Apache httpd 2.4.41 (Ubuntu)
- 139/tcp y 445/tcp — Samba smbd 4.6.2 (NetBIOS: BASIC2)

Hallazgo H-02 — Directorio web oculto accesible

Fase	Enumeración web
Descripción	El servidor web muestra únicamente una página de mantenimiento («Undergoing maintenance»). Mediante fuzzing de directorios se descubrió el directorio oculto /development, accesible sin autenticación y con listado de contenidos habilitado.
Componente afectado	Servidor web Apache (puerto 80)
Categoría	OWASP A01:2021 — Control de acceso roto / exposición de recursos

Herramienta utilizada	gobuster dir (wordlist dirb/common.txt)
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Deshabilitar el listado de directorios en Apache (Options -Indexes); restringir el acceso a directorios internos; no publicar recursos de desarrollo en el servidor.
Riesgo residual	Bajo

Hallazgo H-03 — Información sensible filtrada en archivos de desarrollo

Fase	Enumeración / Recopilación de información
Descripción	Dentro de /development se hallaron dos archivos de texto (dev.txt y j.txt) con notas internas del equipo de desarrollo. Las notas revelan tecnologías en uso, que el servicio SMB fue configurado, y —de forma crítica— que uno de los usuarios posee una contraseña débil que fue crackeada con facilidad por un compañero.
Componente afectado	Archivos internos expuestos en el servidor web
Categoría	CWE-200 — Exposición de información sensible
Herramienta utilizada	Navegador web (inspección manual)
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	No almacenar notas internas en directorios accesibles públicamente; aplicar una política de clasificación de la información.
Riesgo residual	Medio

Hallazgo H-04 — Recurso compartido SMB accesible de forma anónima

Fase	Enumeración de servicios
Descripción	La enumeración del servicio Samba reveló un recurso compartido llamado «Anonymous» accesible sin credenciales. Dentro se encontró el archivo staff.txt, que filtra los nombres de los dos usuarios del sistema: «jan» y «kay».
Componente afectado	Servicio Samba (puertos 139/445)
Categoría	CWE-284 — Control de acceso indebido
Herramienta utilizada	enum4linux-ng, smbclient
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Deshabilitar el acceso anónimo (guest) en la configuración de Samba; requerir autenticación para todos los recursos compartidos.
Riesgo residual	Medio

Hallazgo H-05 — Credenciales débiles: acceso por fuerza bruta a SSH

Fase	Explotación
Descripción	La política de dominio recuperada vía SMB establece una longitud mínima de contraseña de solo 5 caracteres, sin requisito de complejidad (DOMAIN_PASSWORD_COMPLEX: false) y sin umbral de bloqueo por intentos fallidos. Aprovechando esta debilidad y la pista del hallazgo H-03, se ejecutó un ataque de diccionario contra el usuario «jan» por SSH.

	El ataque tuvo éxito: se obtuvo la contraseña del usuario, logrando acceso remoto completo a la máquina como «jan».
Componente afectado	Política de autenticación del sistema / SSH
Categoría	OWASP A07:2021 — Fallos de identificación y autenticación
Herramienta utilizada	hydra (fuerza bruta SSH, diccionario rockyou)
Impacto en la Tríada CIA	Confidencialidad / Integridad / Disponibilidad
Salvaguarda propuesta	Imponer una política de contraseñas robusta (longitud mínima 12+, complejidad obligatoria); habilitar bloqueo por intentos fallidos; implementar autenticación por clave pública en SSH y deshabilitar el login por contraseña; usar fail2ban.
Riesgo residual	Alto (hasta aplicar las salvaguardas)

Hallazgo H-06 — Escalada de privilegios: clave SSH privada expuesta

Fase	Post-explotación / Escalada de privilegios
Descripción	Una vez dentro como «jan», se detectó que la clave SSH privada del usuario «kay» (/home/kay/.ssh/id_rsa) tenía permisos de lectura para otros usuarios. Se copió la clave, protegida por una frase de contraseña, y se crackeó offline con John the Ripper, obteniendo la passphrase. Con la clave y la passphrase se obtuvo acceso como «kay», usuario con privilegios de administrador (sudo), accediendo finalmente a la contraseña final almacenada en su directorio (pass.bak). Se completó así la cadena de ataque de principio a fin.
Componente afectado	Permisos del archivo de clave privada de «kay»
Categoría	CWE-732 — Asignación de permisos incorrecta a un recurso crítico
Herramienta utilizada	ssh, ssh2john, John the Ripper
Impacto en la Tríada CIA	Confidencialidad / Integridad / Disponibilidad
Salvaguarda propuesta	Restringir los permisos de las claves privadas a su propietario (chmod 600); no almacenar claves privadas en ubicaciones legibles por otros; rotar las claves comprometidas; usar passphrases robustas.
Riesgo residual	Crítico (hasta aplicar las salvaguardas)

5. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	1	H-06
Alto	1	H-05
Medio	2	H-03, H-04
Bajo	2	H-01, H-02
Total	6	

6. Post-pentesting: Recomendaciones

6.1. Recomendaciones técnicas (parches y configuraciones)

- Deshabilitar el listado de directorios en Apache y retirar los recursos de desarrollo del servidor público (H-02, H-03).
- Deshabilitar el acceso anónimo en Samba y exigir autenticación para todos los recursos compartidos (H-04).
- Reforzar la política de contraseñas: longitud mínima de 12 caracteres, complejidad obligatoria y bloqueo tras varios intentos fallidos (H-05).
- Configurar SSH para autenticación por clave pública, deshabilitar el acceso por contraseña e instalar fail2ban (H-05).
- Restringir los permisos de las claves privadas a su propietario (chmod 600) y no almacenarlas en ubicaciones legibles por otros usuarios; rotar las claves comprometidas (H-06).
- Reducir la superficie de ataque: exponer solo los servicios imprescindibles y aplicar reglas de firewall (H-01).

6.2. Recomendaciones administrativas (políticas y procesos)

- Establecer una política de clasificación y manejo de la información que impida publicar notas internas.
- Capacitar al personal de desarrollo en prácticas seguras de despliegue y en el manejo de credenciales.
- Realizar auditorías de seguridad periódicas sobre los servicios expuestos.

7. Protocolo de contingencia

7.1. Escenario de falla

El procedimiento con mayor potencial de causar una interrupción es el ataque de fuerza bruta contra SSH (H-05): un volumen elevado de intentos de autenticación podría agotar recursos del servidor o disparar bloqueos que impidan el acceso legítimo de los usuarios.

7.2. Impacto sobre la continuidad del negocio

En un entorno de producción, una interrupción del servicio de autenticación afectaría el acceso de los empleados a los sistemas internos y, potencialmente, la atención a clientes. En el entorno de laboratorio el impacto es nulo, al tratarse de una máquina aislada y desechable.

7.3. Plan de respuesta

1. Activación: se detecta la falla mediante el monitoreo de disponibilidad del servicio y los registros de autenticación.
2. Contención: en los primeros 15 minutos se detiene la actividad de prueba y se aíslan las conexiones sospechosas.
3. Recuperación: se restaura el servicio desde copia de respaldo o servidor espejo, o se revierte la configuración (rollback).
4. Comunicación: se notifica a la dirección, al responsable de sistemas y, si corresponde, a los usuarios afectados.
5. Post-mortem: se documenta el incidente y se incorporan las lecciones aprendidas al plan de seguridad.

7.4. RTO y RPO estimados

RTO (Recovery Time Objective)	4 horas
RPO (Recovery Point Objective)	24 horas

8. Declaración ética

Declaro que todas las actividades descritas en este informe se realizaron dentro del alcance autorizado, en entornos controlados de la plataforma TryHackMe y con fines exclusivamente académicos. No se aplicaron las técnicas aquí documentadas contra ningún sistema real o de terceros.

Nicolas Estrella — Legajo 31.066.692

9. Anexo C — Hashes de las flags obtenidas

En cumplimiento del mecanismo de control de autenticidad de la actividad, se presentan los hashes SHA-256 de las flags obtenidas, en lugar de las flags en texto plano. El hash permite al docente verificar la obtención sin exponer la flag.

Flag / Sala	Hash SHA-256
Introducción a Offensive Security	2f55167e73a32bc73afaa64cba2c39892f13ca52ba421270147256edff1dbc3d
Pentesting Fundamentals (ejercicio ACME)	583f30ba446f9f74d509726d25956b4b75ad965f953feffc996f6ad1382dc8d6

Nota: el hash SHA-256 se calcula sobre la flag exacta, sin salto de línea final (comando: `printf '%s' "<flag>" | sha256sum`).